CyberRiskGuardian Case Library

Five fictional business cases for teaching — Education Package 1.0

Marc-André Léger, PhD

October 2026

1 About the cases

The five cases in this library are fictional organizations written for cybersecurity, audit, governance, privacy and risk-management courses. They share one structure (version 2.0c), so students who learn the method on one case can apply it to another:

- **Module A — Incident response:** a live or simulated incident and the decisions it requires.
- **Module B — Audit planning:** an audit universe and a risk-based audit plan.
- **Module C — Risk management:** risk appetite, a scenario library and a risk register.
- **Assignment options 1–3:** incident tabletop, audit plan, risk assessment with a multi-year roadmap.

The student versions in `cases/` contain the narrative, the evidence appendices and the scenario library. The instructor annexes (detailed scenarios with illustrative parameter values, sample answers, progressive-release plans and calibration notes) are in the Educator Edition.

The cases are fictional. They are realistic but do not describe any real organization, regulator, vendor, employee, customer or incident. Figures are teaching assumptions.

2 Choosing a case

Case	Sector	Scale	Stated cyber tolerance	Scenario library	Difficulty	Best for
Chez Pierre	Restaurants (corporate and franchise)	30 restaurants; IT team of about 32; cyber budget CAD 1.3M	0.4	9 prompts	Introductory	First risk assessment; business-technology courses; strategy discussion
MediBec	Private healthcare	Head office and 10 clinics; 15 IT staff, 2 in cybersecurity; IT budget CAD 100M	0.40 (executive review above 0.25, Board above 0.40)	15 scenarios	Intermediate	**The lab case** (fully worked example published); health privacy; patient-safety trade-offs
Ca	National	100 stores and e-	0.5 (risk-	50	Int	The graded A1 assignment with

Case	Sector	Scale	Stated cyber tolerance	Scenario library	Difficulty	Best for
naRetail	retail	commerce; about 62 IT staff; IT budget CAD 150M (2026)	neutral)	prompts + 9 supplied scenarios	ermediate	the CRG Excel model (Module D is built for it); payment security; budgeting
ACRB	Regional bank	30 branches; about 750 staff, 83 in IT; 2022 breach	0.30 (executive review above 0.20, Board above 0.30)	15 scenarios	Advanced	IT audit with prior findings; regulated sector; board reporting; post-incident recovery
CNIC	National insurer	More than 3 million clients; IT budget CAD 315M, of which 50M cybersecurity	0.34 (executive review above 0.20, Board above 0.34)	12 scenarios	Advanced	Large enterprise; AI governance (AI claims platform); capstone and graduate seminars

Recommended pattern. Use **MediBec** for the labs (students can check themselves against the published worked example) and assign a **different** case for graded work. Rotate cases between terms and sections. A sixth case, reserved for the final exam, is in the Educator Edition.

3 Using a case with CyberRiskGuardian

1. **Create a workspace for the case.** Desktop: Organization → Workspaces → *New workspace*, type *Classroom business case*, tick *Educational case used for training purposes*, drop the case document and extract the profile and crown jewels. Claude: attach the case document and run `/crg-assess` or `/crg-quick-scan`.
2. **Use the case's tolerance as the starting appetite.** Students may propose a different value but must justify it (Lab 2).
3. **Treat the scenario library as candidates, not answers.** Library entries are short themes. Students must rewrite each one they keep as a complete causal chain grounded in the case.
4. **Translate the case's scoring model into CRG's.** Most cases describe a simple normalized model (threat × exposure × impact, adjusted for control maturity) with escalation thresholds. CRG uses six parameters and a tolerance ratio. The two lenses can disagree; students should say which one a governance threshold refers to.
5. **Use CRG's definition of μ(E).** In CyberRiskGuardian, μ(E) is the *organizational criticality* of the affected service or process. Some case texts use the label "expected utility" in other senses (for example, for mitigation measures, or as a product of other factors). For CRG work, always estimate μ(E) as criticality.
6. **Check every CVSS score against its vector.** Compute scores with a calculator; never copy a score without its vector.

Version 2.0c. The cases in this package are version 2.0c: μ(E) is labelled *organizational criticality* throughout, in line with CyberRiskGuardian, and the CVSS scores in the instructor material were recomputed from their vectors.

4 The cases

4.1 Chez Pierre — fine dining (introductory)

Organization. A Montreal restaurant group founded in 2005, with 10 corporate-owned restaurants (Montréal, Mont-Tremblant, Québec City, Ottawa, Toronto, Mississauga, Edmonton, Banff, Vancouver, Whistler) and 20 franchised restaurants.

What matters. Point-of-sale and payment processing, online reservations, online ordering (app, website, delivery platform), central data management (recipes, supplier contracts, employee and financial records), CRM and loyalty, inventory and supplier integration, guest Wi-Fi and connected kitchen equipment.

Risk context. Cybersecurity tolerance 0.4, described as moderately risk-averse; low appetite for cybersecurity, privacy, operational, compliance and reputational risk. 2024 IT budget lines: operations CAD 5.6M, development 3.0M, cybersecurity 1.3M, salaries 6.4M. Payment-card security (PCI DSS) and Canadian privacy requirements are named.

Scenario prompts (9). Phishing on corporate e-mail · ransomware on the reservation system · POS malware · insider leak · DDoS on online ordering at peak hours · man-in-the-middle on restaurant Wi-Fi · weak administrative passwords · social engineering for credentials · zero-day on unpatched software.

Teaching angles. The franchise model (who controls local technology?), a small cybersecurity budget, the business-strategy questions that surround the risk analysis. A good first case: plain business context, few scenarios, one tolerance value. The risk-assessment option asks for at least six scenarios.

4.2 MediBec — private healthcare (intermediate; lab case)

Organization. A private medical centre with a Montreal head office and 10 clinics in the Montreal, Quebec City, Gatineau and Saguenay regions.

What matters. The electronic health record; radiology, laboratory and pharmacy systems; billing; scheduling and online patient services; identity and remote access; the Montreal data centre, WAN and backups; connected medical equipment; clinician communications.

Risk context. Low appetite for patient safety, health-data confidentiality, compliance and public trust; normalized tolerance 0.40; residual risk above 0.25 requires executive review and above 0.40 requires Board or ownership-group acceptance. A lean IT department of 15 with two cybersecurity staff; IT budget CAD 100M; 2024–2030 roadmap. Multiple unsuccessful attacks since 2020, increasing recently; no confirmed breach.

Scenario library (15). MED-CYR-01 to MED-CYR-15: credential compromise, ransomware on the EHR, cloud misconfiguration, API key exposure, clinic wireless compromise, delayed patching, exposed backup servers, inadequate intrusion detection, medical device or IoT foothold, DDoS on patient services, insider exfiltration, phishing of staff, data-integrity attack on patient or billing records, vendor compromise, untested incident response.

Teaching angles. Containment decisions with clinical consequences; whether tolerance should differ between administrative and care systems; prioritizing with a two-person team. The published CRG assessment (30 scenarios; 84,305 estimated and 41,023 residual) and the desktop application's MediBec simulation pack (three weeks of SOC activity) make it the natural lab case.

4.3 CanaRetail — national retail (intermediate)

Organization. A Montreal-headquartered retailer (stores operating as Maison Helenas) with 100 stores across Canada and a national e-commerce platform.

What matters. E-commerce and payment gateways, POS terminals in 100 stores, the SAP S/4HANA ERP, loyalty and CRM data, cardholder data, inventory, the Montreal data centre, backups and recovery sites; AWS and Azure; IoT in stores (smart shelves, cameras, NFC tags).

Risk context. Overall appetite moderate, "risk neutral (0.5)", with low appetite for data breaches and reputational damage and very low appetite for regulatory, privacy and payment-compliance risk; online sales outages should not exceed 24 hours. 2026 IT budget CAD 150M including salaries; cybersecurity allocation rising from CAD 6.2M (2023) to CAD 26.57M (2031) in the case's projection. Students are invited to challenge the appetite statement.

Scenario prompts (50). Fifty short themes, from executive phishing, ransomware and POS malware to IoT botnets, API weaknesses, shadow IT and teleconferencing eavesdropping. **Module D** asks teams to combine one original scenario with **nine supplied scenarios** in the CRG Excel model; the instructor distributes those nine as a handout (supplied in the Educator Edition).

Teaching angles. Built for the A1 assignment with the CRG workbook; payment security; budgeting against the appetite-consistent target (7.8% of the IT budget at the case's appetite of 0.5); a sensitive framing about identity-based targeting that instructors may want to introduce in class.

4.4 ACRB — Atlantic Canada Regional Bank (advanced)

Organization. A federally regulated community bank headquartered in Halifax, founded in 1952, with 30 branches, about 750 employees (83 in IT), about 800 ATMs and 700 POS terminals.

What matters. A 1970s proprietary core banking system, online and mobile banking, ATM and POS networks, customer data (including social insurance numbers), the Halifax data centre and Moncton recovery site, identity services, branch connectivity.

Risk context. In 2022 a spear-phishing campaign led to two weeks of undetected presence, ransomware and suspected exfiltration of data on more than 100,000 customers, about one week of disruption and CAD 2M of immediate damage; leadership changed and a CISO role was created. Normalized tolerance 0.30; residual risk above 0.20 requires executive review and above 0.30 requires Board acceptance. Prior internal-audit findings (asset inventory, phishing reporting, legacy vulnerabilities, no ransomware tabletop, limited restore testing). OSFI Guideline B-13, OSFI incident reporting and PIPEDA breach guidance are named.

Scenario library (15). CYR-01 to CYR-15: spear-phishing to ransomware, privileged-account compromise, legacy core-banking exploitation, cloud misconfiguration, payment-processor compromise, mobile API weakness, departing insider, SOC alert fatigue, backup compromise, ATM/POS malware, DDoS during a public incident, unmanaged personal devices, certificate lifecycle failure, physical breach at the data centre, abuse of vendor remote access.

Teaching angles. Audit planning with real prior findings; regulatory reporting deadlines; board reporting after a crisis; CISO independence. Best for audit courses and advanced students.

4.5 CNIC — Canadian National Insurance Company (advanced)

Organization. A national insurer founded in 1968, headquartered in Montreal, with more than 3 million clients and offices in Toronto, Vancouver, Montreal, Calgary and Halifax; data centres in Montreal and Calgary.

What matters. An AI-enabled claims platform (intake, triage, fraud detection, payments), an AI-driven CRM, SAP ERP, customer portal, mobile app and AI voice response, personal, medical, claims and financial data, a hybrid AWS/Azure cloud, outsourced claims processors and vendors.

Risk context. Normalized tolerance 0.34; residual risk above 0.20 requires executive review and above 0.34 Board acceptance; an additional threshold for AI risk. FY2025 IT budget CAD 315M, of which CAD 50M is cybersecurity (about 16% — worth discussing against the 4%–12% guideline). In the source case the CISO reports to the CIO.

Scenario library (12). CNIC-01 to CNIC-12: ransomware on data centres, vendor breach, insider exfiltration, executive spear-phishing, cloud misconfiguration, DDoS on the portal, APT, BYOD malware, IoT hijacking, weak password policies, AI claims manipulation or model-integrity failure, leakage from analytics or CRM.

Teaching angles. AI governance and model risk; a very large budget; CISO reporting line; less scaffolding than the other cases. Best for capstones, graduate seminars and Model 4 of the Instructor Guide.

5 Using the cases responsibly

- **Do not copy example figures.** Worked examples, annex values and sample memos use illustrative numbers. Students must use their own case's facts and their own estimates.
- **Note inconsistencies.** Like real organizations' documents, cases can contain figures that do not agree. Students who find one should note it, say which figure they used and why.
- **Label external facts.** Statistics or legal obligations that do not appear in the case must be cited from a primary source, or labelled as assumptions.
- **AI and fictional data.** The cases are fictional and safe to use with AI tools. Real organizations' documents are not, unless the organization and the institution authorize it.

© 2026 Marc-André Léger. Cases licensed under CC BY-NC 4.0 for non-commercial teaching. All organizations, people and events are fictional.